BÖLÜM 7: GÜVENLIK VE SIFIR GÜVEN — KRALLIĞI SAVUNMAK

9 dk • DERS 28

Parça 28: Tedarik Zinciri Güvenliği ve Tehdit Modellemesi (STRIDE)

Kötü niyetli npm paketlerinden korunmak ve tasarım aşamasında STRIDE risklerini hesaplamak.

🔥 SAHADAN YAŞANMIŞ KRİZ HİKAYESİ

2018 yılında haftalık 2 milyon indirilen açık kaynaklı JavaScript kütüphanesi `event-stream`'in yorgun geliştiricisi, repoyu yardım teklif eden tanımadığı birine devretti. Yeni sahip kütüphaneye sessizce `flatmap-stream` adında minik bir bağımlılık ekledi. Bu bağımlılığın içinde açık kaynaklı Copay Bitcoin cüzdanındaki özel anahtarları çalmak üzere şifrelenmiş zararlı bir kod vardı! Aylarca yazılımcılar hiçbir şeyden habersiz `npm install` diyerek bu truva atını kendi ticari yazılımlarına çektiler. Şirketlerin kendi kodlarında tek satır değişiklik olmamasına rağmen sistemlerinde truva atı çalışıyordu.

Zihniyet Dönüşümü: Kod Yazarlığından Mimarlığa

Modern yazılımlar sıfırdan yazılmaz; binlerce açık kaynaklı bağımlılıktan monte edilir. Siz 1.000 satır özel kod yazdığınızda, internetteki yabancıların yazdığı 500.000 satırlık üçüncü parti kodu projenize dahil edersiniz. Güvenlik sınırınız `node_modules` içindeki en zayıf paket kadardır. Mimari güvenlik; otomatik Yazılım Malzeme Listesi (SBOM) takibi, zafiyet taramaları ve tasarım aşamasında **STRIDE Tehdit Modellemesi** gerektirir.

Temel Mimari İlkeler ve Zihinsel Modeller

STRIDE Tehdit Modelleme Çerçevesi (Microsoft Standardı)

Sistemi inşa etmeden önce her bileşeni şu 6 tehdide karşı test et:

- **S - Spoofing (Kimliğe Bürünme):** Saldırgan başka bir kullanıcının veya servisin yerine geçebilir mi?
- **T - Tampering (Veri Tahrifatı):** Veri yolda veya veritabanında fark edilmeden değiştirilebilir mi?
- **R - Repudiation (İnkar Edilebilirlik):** Kullanıcı yaptığı işlemi inkar edebilir mi (denetim logu eksikliği)?
- **I - Information Disclosure (Bilgi İfşası):** Gizli veriler yetkisiz kişilere sızabilir mi?
- **D - Denial of Service (Hizmet Engelleme):** Sistem aşırı yükle çökertilebilir mi?
- **E - Elevation of Privilege (Yetki Yükseltme):** Normal kullanıcı yönetici haklarına sıçrayabilir mi?

Tedarik Zinciri Kalkanları (SBOM ve Kilit Dosyaları)

1. **Kilit Dosyaları:** `package-lock.json` veya `poetry.lock` dosyalarını mutlaka git'e atın.
2. **Otomatik Tarama:** CI/CD'de Dependabot veya Snyk çalıştırın.
3. **Özel Paket Deposu:** Açık kaynaklı paketleri doğrudan internetten değil, taranmış şirket içi artifact reposundan (Nexus/Artifactory) çekin.

Kaçınılması Gereken Anti-Pattern'ler ve Tuzaklar

- **Ucu Açık Versiyonlar:** Kilit dosyası kullanmadan `package.json` içine `*` veya `^` koyup gece derlemesinde güncellenen zararlı paketi canlıya çekmek.
- **Güvenlik Uyarılarını Görmezden Gelmek:** Dependabot'un bildirdiği 'Kritik' açık uyarılarını aylarca kapatmayıp spam muamelesi yapmak.

- **Kör Konteyner Güveni:** Docker Hub'dan kimin hazırladığı belli olmayan rastgele taban imajları (`FROM ahmet/python`) indirip kullanmak.

> **🎯 MİMARIN EYLEM PLANI: BU HAFTAKİ SOMUT ADIMLAR**
>
> - **1. Adım:** Bir sonraki büyük mimari tasarımında 1 saatlik STRIDE tehdit modelleme toplantısı yap.
> - **2. Adım:** CI/CD sürecine Kritik güvenlik açığı tespit ettiğinde derlemeyi durduran otomatik bağımlılık tarayıcı ekle.
> - **3. Adım:** Üretim paketleriniz için otomatik bir Yazılım Malzeme Listesi (SBOM) çıktısı üret.

Mimari Çıkarımlar ve Hile Tablosu

- Projenize dahil ettiğiniz her üçüncü parti satır kodun güvenliğinden bizzat siz sorumlusunuz.
- STRIDE, açıkları olay yaşandıktan sonra değil, tasarım aşamasında bulmanızı sağlayan sistematik bir pusuladır.
- Bağımlılıklarınızı kilitleyin, paketlerinizi tarayın ve açık kaynak dünyasına tedbirli yaklaşın.

> **🎙️ UDEMY & NOTEBOOKLM TARTIŞMA VE ÖDEV SORUSU**
>
> **Ders Değerlendirmesi ve Ödev:** Projenizde `npm audit` veya `pip audit` çalıştırın. Kaç güvenlik açığı listelendi? Kaç tanesi 'High' veya 'Critical' seviyesinde?